信息安全测评与风险评估



4.4 应用系统安全功能验证

授课教师：张玉

目录

CONTENTS

01 案例导入：改一个订单号，就能看到别人的信息

02 关键知识：四个维度怎么验

03 动手实验：西普平台 WVS Web 扫描 + 记录表判定

04 回顾拓展：易错点、作业与下节预告

Part.01

案例导入

——

改一个订单号，就能看到别人的信息



案例导入——一次越权访问引发的数据泄露

素材1：案例导入文字材料.docx



应用系统的“身份证”和“门禁系统”靠谱吗？

案例：某电商平台发生数据泄露。攻击者发现订单查询接口存在越权漏洞：只需修改URL中的订单ID参数，即可查看他人订单信息。

漏洞： 水平越权　　方式： 修改URL参数

范围： 数百万用户信息　　后果： 信任受损

先想一想（30 秒）

- 1. 这个漏洞对应等保哪一条？（提示：8.1.4.2 访问控制）
- 2. 不拿源码、不改代码，你怎么把它测出来？
- 3. 越权之外，这个系统还可能漏了什么？

学习目标

学完这一节，你应该能做到：

理解

说清应用系统在等保里主要测哪些维度

掌握

在浏览器和靶场上亲手验口令复杂度、登录失败锁定、空闲超时与传输加密

掌握

用改参数、换账号的办法把垂直越权和水平越权真正测出来

能够

把 WVS 扫描结果录入测评记录表、做四档判定，产出规范的测评记录表

具备

对不合规项写出可执行的整改建议，说清"差在哪、怎么改"

Part.02

关键知识——测哪些维度？



应用系统安全功能验证

- 在等保标准中的位置：GB/T 22239-2019安全技术要求 → 安全计算环境
- 应用系统属于安全计算环境的一部分，核心测评维度：

序号	维度	标准要求节	核心关注点
1	身份鉴别	8.1.4.1	用户身份认证是否可靠
2	访问控制	8.1.4.2	用户权限管理是否严格
3	安全审计	8.1.4.3	操作日志记录是否完整
4	数据完整性	8.1.4.7	重要数据是否被篡改

本节课重点：身份鉴别 + 访问控制 + 安全审计（占90%）

身份鉴别测评——核心检查项

身份鉴别的目标是：**验证“你是谁”**

GB/T 22239 8.1.4.1 身份鉴别要求：

序号	检查项	内容	测评方法
a)	**身份唯一性**	每个用户应有唯一标识，鉴别信息具复杂度并定期更换	看管理界面 + 查密码策略
b)	**登录失败处理**	配置结束会话、限非法登录次数、连接超时自动退出	模拟连续错误登录测试
c)	**远程管理安全**	远程管理时，鉴别信息不应在网络中明文传输	抓包分析 / 查看协议
d)	**多因素认证**	采用口令、密码技术、生物技术等组合（三级及以上）	查看认证配置

身份鉴别怎么验①——口令复杂度

素材3：模拟测试用例——身份鉴别

检查项a：密码复杂度与更换周期

合格标准

- 密码最小长度≥8位
- 含大小写字母、数字、特殊字符中的至少3类
- 密码有效期≤90天
- 禁止使用前5次密码

验证方法

1. 尝试: "123456"➔ 预期：被拒绝
2. 尝试: "Password123"➔ 预期：被拒绝(缺特殊字符)
3. 尝试: "P@ssw0rd123"➔ 预期：通过
4. 确认密码有效期设置

常见问题

- ✕密码复杂度未强制
- ✕密码永不过期
- ✕未禁止重复使用旧密码

身份鉴别怎么验②——登录失败与会话超时

检查项b：登录失败处理

合格标准：

- 连续失败**5次**锁定（或限制）
- 锁定时间≥**15分钟**（或需解锁）
- 空闲超时≤**15分钟**自动退出

验证方法：

步骤： 连续输入错误密码5次

预期： 账户锁定或提示15分钟后重试

锁定再试： 预期被拒绝

闲置15分： 预期自动退出需重认

常见问题：

- ✕ 无失败次数限制
- ✕ 无空闲超时退出
- ✕ 锁定后立即可重试



身份鉴别怎么验③——远程管理是否加密

检查项c：远程管理安全

合格标准

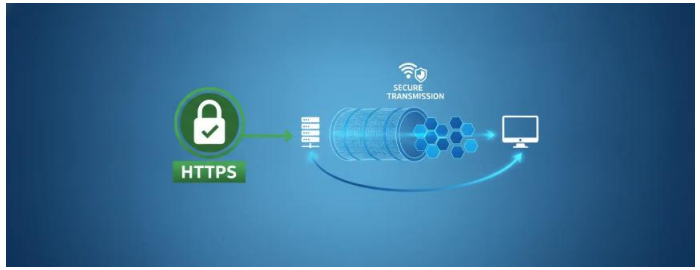
- 远程管理应采用加密协议（HTTPS、SSH等）
- 不应使用明文传输协议（HTTP、Telnet、FTP等）

验证方法

- 查看应用系统的访问协议（地址栏是否为https://）
- 如果支持HTTP，查看是否自动跳转到HTTPS
- 使用抓包工具（如Wireshark）验证数据是否加密
- 检查是否部署了有效的数字证书

常见问题

- ✗ 仅支持HTTP，未启用HTTPS
- ✗ HTTPS未强制（可降级为HTTP）
- ✗ 自签名证书（浏览器提示不安全）



访问控制测评——核心检查项

访问控制的目标是：验证“你能做什么”

GB/T 22239 8.1.4.2 访问控制要求：

序号	检查项	内容	测评方法
a)	账户分配	登录用户应分配账户和权限	查看用户权限配置
b)	默认账户	应重命名或删除默认账户，修改默认口令	查看默认账户状态
c)	过期账户	及时删除或停用多余的、过期的账户	查看账户列表
d)	最小权限	授予管理用户所需的最小权限，实现管理用户的权限分离	查看权限分配
e)	授权主体	应由授权主体配置访问控制策略	查看权限管理流程
f)	粒度控制	访问控制粒度应达到用户级/进程级，客体为文件/数据库表级	查看权限配置
g)	安全标记	应对重要主体和客体设置安全标记（三级及以上）	查看标记配置

访问控制验证——两种越权漏洞

越权漏洞是应用系统最严重的安全问题之一。

垂直越权
(Vertical Privilege Escalation)

定义： 低权限用户获取高权限操作

示例： 普通用户访问管理员后台

测试：
① 普通用户登录
② 尝试访问/admin
③ 预期：被拒绝

风险： 高危

水平越权
(Horizontal Privilege Escalation)

定义： 访问其他同级用户的数据

示例： 用户A修改ID查看用户B订单

测试：
① 用户A登录
② 修改资源ID参数
③ 预期：无法查看

风险： 高危

安全审计测评——核心检查项

安全审计的目标是：记录“你做了什么”

GB/T 22239 8.1.4.3 安全审计要求：

序号	检查项	内容
a)	审计启用	应启用安全审计功能，审计覆盖到每个用户，对重要的行为和事件进行审计
b)	审计内容	记录应包括日期时间、用户、事件类型、是否成功及其他相关信息
c)	审计保护	应对记录进行保护，定期备份，避免未预期的删除、修改或覆盖
d)	进程保护	应对审计进程进行保护，防止未经授权的中断（三级及以上）

安全审计怎么验⑥——日志有没有、全不全

验证方法：

测试场景	操作	预期结果
登录审计	成功登录一次、失败登录一次	审计日志中应有两条记录，包含用户名、登录时间、来源IP、成功/失败状态
权限变更审计	管理员修改用户权限	审计日志中应有记录，包含操作人、操作时间、操作内容
重要操作审计	删除数据、修改配置	审计日志中应有记录，包含操作人、操作时间、操作内容
日志保护验证	尝试普通用户删除审计日志	被拒绝（仅审计管理员可操作）

常见问题：

- 未启用审计功能
- 审计日志不完整（缺少关键字段）
- 审计日志可被普通用户删除

Part.03

动手实验

——

西普平台 WVS Web 扫描



实验①做什么——本讲实验任务与清单

项目	说明
实验名称	应用系统安全功能验证（西普平台 WVS Web 扫描 + 记录表判定）
实验环境	西普实验平台（10.11.0.70）「应用系统安全测评」实验： 使用 WVS 进行 Web 扫描 / Web 应用扫描结果分析
实验清单 （W1 → W2） 按顺序做	① W1 使用 WVS 进行 Web 扫描：对平台靶站新建扫描任务，执行完整扫描并导出报告 ② W2 Web 应用扫描结果分析：按高 / 中 / 低危分档，锁定需人工复核的缺陷（弱口令 / 注入 / 越权） ③ 填写《应用系统安全测评记录表》： 身份鉴别 / 访问控制 / 安全审计逐条填实测结果 + 四档判定

实验③交什么——成果与提交前自查

要求

① 平台登录与实验列表截图（含个人信息、实验名称、完成状态）

② 命名：班级-学号-姓名-4.4实验_记录表.docx 和 班级-学号-姓名-4.4实验_截图.zip

③ 提交至学习通 → 任务 4.4 → 作业区（课内完成并提交）

④ 自查：□ 每条判定都有截图或抓包 □ 核查结果写的是事实不是结论

Part.04

回顾与拓展——易错点、作业与下节预告



职业提醒——你放过的那次越权，会变成别人的信息泄露

守护

- 应用系统承载着海量用户数据
- 一次安全功能失效，可能导致千万用户信息泄露
- 每一次验证，都是在守护用户隐私

担当

- 《个保法》规定处理个人信息遵循“最小必要”原则
- 系统安全功能合规，是法律的基本要求
- 测评工程师为“依法治网”提供技术支撑

匠心

- 越权漏洞隐藏在参数、请求体等细微之处
- 需耐心细致，不放过任何一个可疑点
- 精益求精是对职业的敬畏与对用户负责

一句话：你多试一次越权，上线后就少一次真实的信息泄露。

知识点回顾

应用系统安全功能验证

一、身份鉴别验证

唯一性与复杂度（密码策略）

登录失败处理（锁定机制）

远程管理安全（加密协议）

多因素认证（三级以上）

二、访问控制验证

账户管理（默认/最小权限）

垂直越权测试（低→高权限）

水平越权测试（同级用户数据）

三、安全审计验证

- 审计功能是否启用
- 审计内容是否完整
- 审计记录是否受保护

四、常见安全问题

- 密码策略未强制
- 无登录失败限制
- 越权漏洞
- 审计功能缺失

下节课预告

活动4.5：漏洞扫描与结果分析

预告内容：

- 漏洞扫描原理（漏洞库匹配、端口扫描、服务识别）
- 漏洞扫描工具使用（Nessus/OpenVAS）
- 扫描报告解读（CVSS评分、漏洞分类、修复建议）
- 漏洞验证与风险评估

课前准备：

- 复习漏洞扫描的基本原理
-

谢谢观看

THANKS FOR WATCHING